THOMSON COURSE TECHNOLOGY

Guide to Network Defense and Countermeasures Third Edition

Chapter 14

Ongoing Security Management

Objectives, Part 1

- Strengthen network control by managing security events
- Improve analysis by auditing network security procedures
- Strengthen detection by managing an intrusion detection system

© Cengage Learning 2014

Objectives, Part 2

- Improve network defense by changing a defense in depth configuration
- Strengthen network performance by keeping pace with changing needs
- Increase your knowledge base by keeping on top of industry trends

© Cengage Learning 2014

Strengthening Control: Security Event Management, Part 1

- Network devices that may already be in place
  - Packet-filtering routers
  - VPN appliances
  - IDPS at each branch office
  - One or more firewalls at each office
  - Event logs or syslogs (system logs)

© Cengage Learning 2014

Flow of Information from Multiple Sources

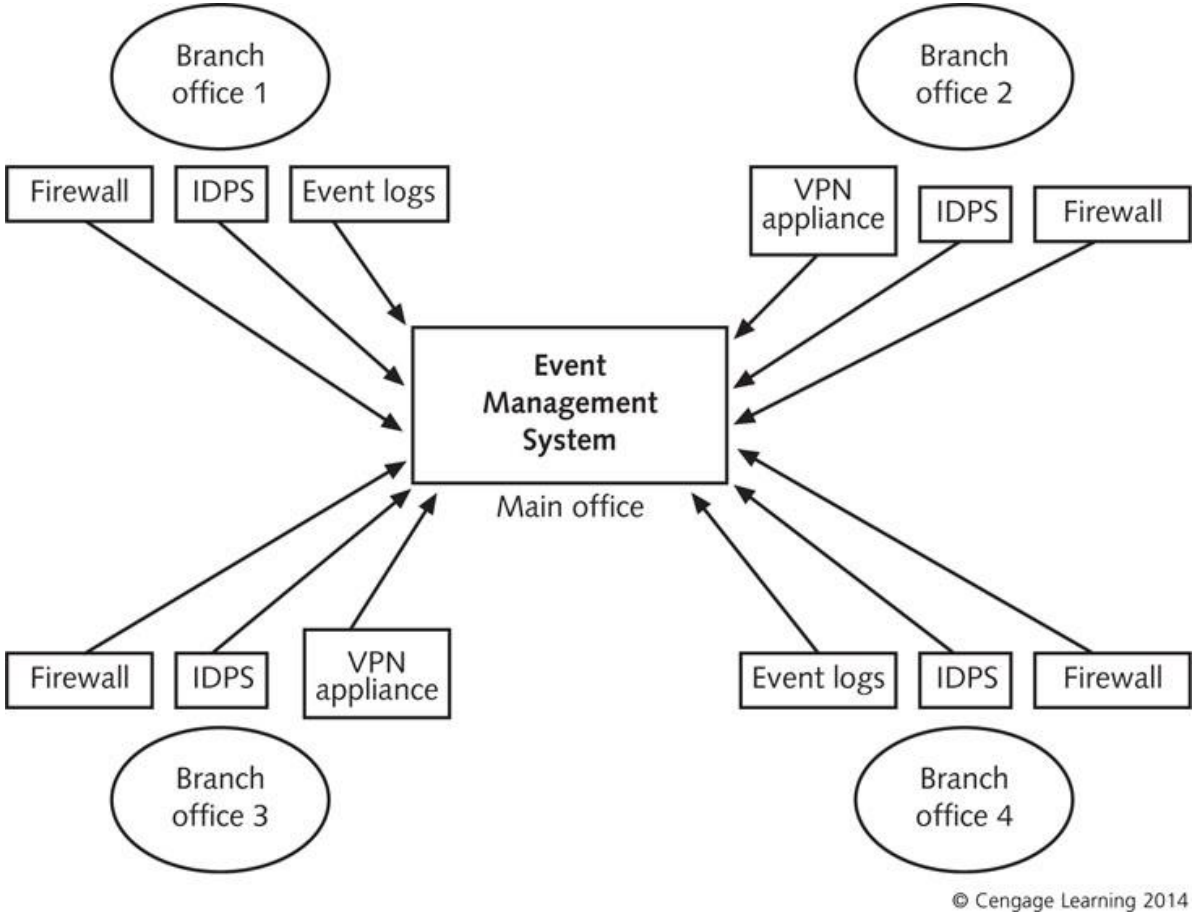

Figure 14-1 Flow of information from multiple sources

Strengthening Control: Security Event Management, Part 2

- Security event management program
  - Gathers and consolidates events from multiple sources
  - Helps analyze the information to improve network security

© Cengage Learning 2014

Monitoring Events, Part 1

- Event monitoring
  - Review alert and event logs that your security devices and OSs produce
  - Test network periodically to identify weak points
- Monitor following events
  - Logins
  - Creation of user accounts and groups
  - Correct handling of e-mail attachments
  - Backups
  - Antivirus scanning and control
  - Procedures for granting secure remote access

© Cengage Learning 2014

Monitoring Events, Part 2

- Your responses need to occur as quickly as possible
- Develop a team approach to network security
- Make use of automated responses
  - Alarms systems built into an IDPS
- Coordinate data from multiple sources
- Keep aware of new network security threats

© Cengage Learning 2014

Managing Data from Multiple Sensors, Part 1

- When an organization has offices in several countries or in separate states:
  - Each office network may have its own firewall and IDPS
- How do you process all the events at these offices?
  - Install database software that sorts through events and enables you to view them systematically

© Cengage Learning 2014

Managing Data from Multiple Sensors, Part 2

- Centralized data collection
  - Organization's event and security data are "funneled" to a centralized management console at main office
  - Benefits
    - Reduced cost
    - Less administrative time
    - Improved efficiency
  - Disadvantage
    - Needs secure communication channel from each collection point to the centralized management console

© Cengage Learning 2014

Centralized Data Collection

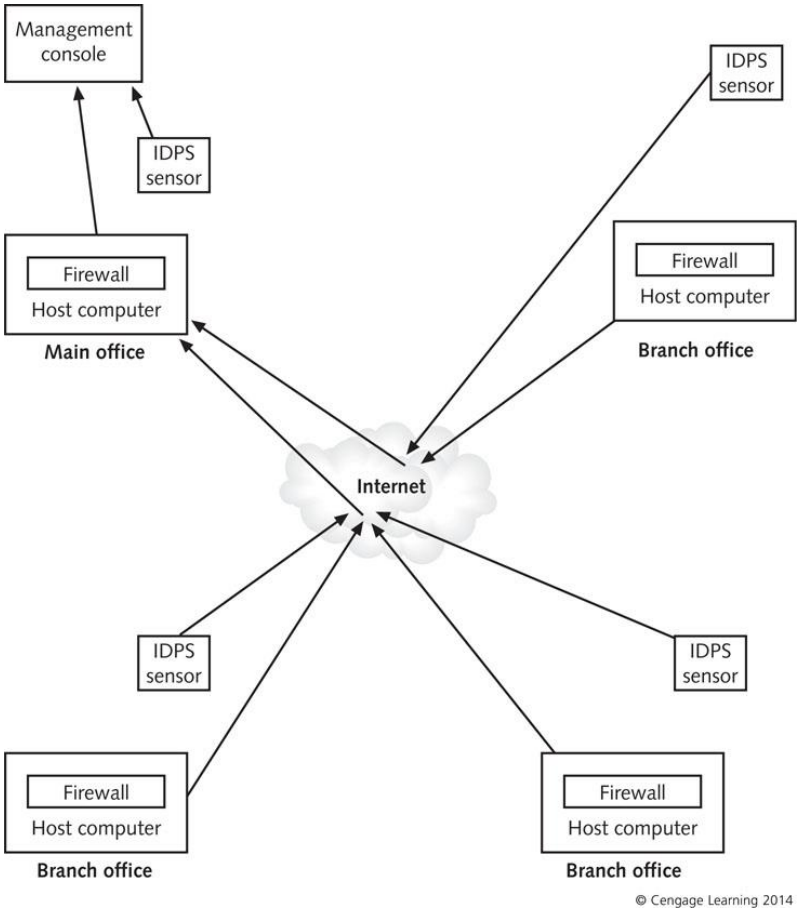

Figure 14-2 Centralized data collection

Managing Data from Multiple Sensors, Part 3

- Distributed Data Collection
  - Data from a security device goes to a management console on its local network
  - Security managers review the data and respond to events separately
  - Advantage
    - Saves bandwidth
  - Disadvantages
    - Requires a security manager at each location
    - Security managers need to talk to each other in the case of an event

© Cengage Learning 2014

Distributed Data Collection

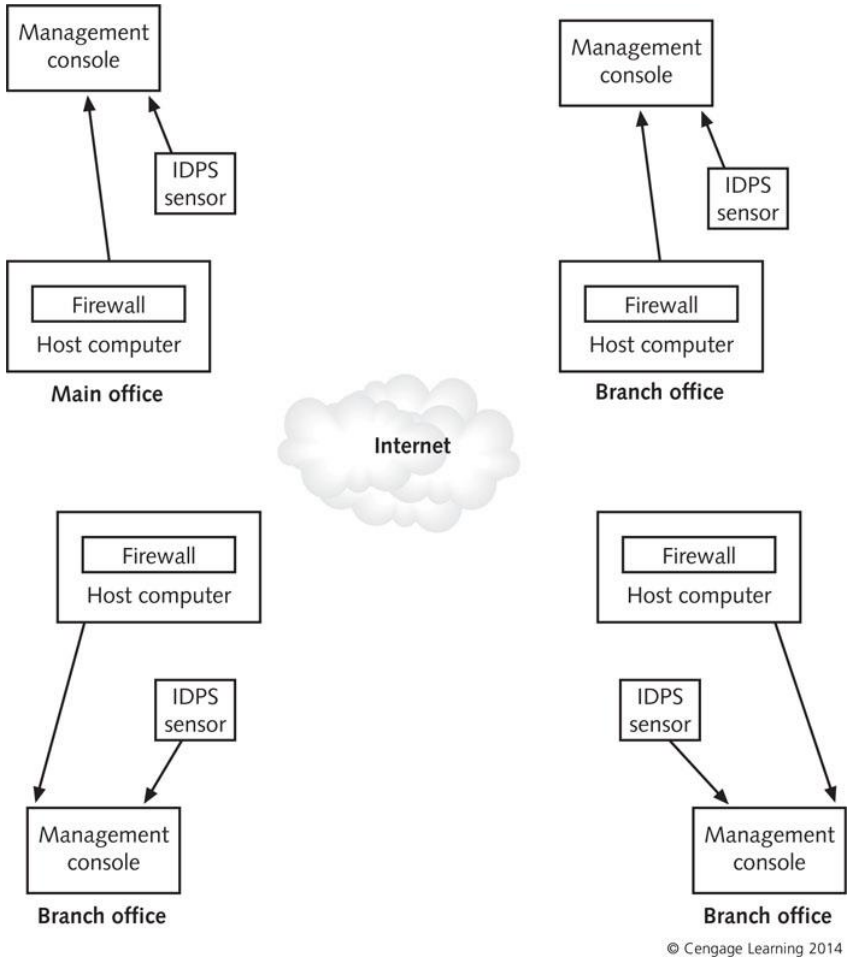

Figure 14-3 Distributed data collection

Evaluating IDPS Signatures

- Gather evidence that indicates whether your IDPS signatures are working well or need to be updated
- Process of updating IDPS signatures varies depending on the vendor
  - Check the vendor's Web site for complete instructions
- Your organization might also hire a security management firm to handle these routine tasks

© Cengage Learning 2014

Managing Change

- Changes should be carried out systematically
- Change management involves:
  - Modifying equipment, systems, software, or procedures in a sequential, planned way
  - Should include an assessment of the impact
- Consider using change management for
  - Significant changes to firewalls and IDPSs
  - New VPN gateways
  - Changes to access control lists
  - New password systems or procedures

© Cengage Learning 2014

Communication of Significant Changes

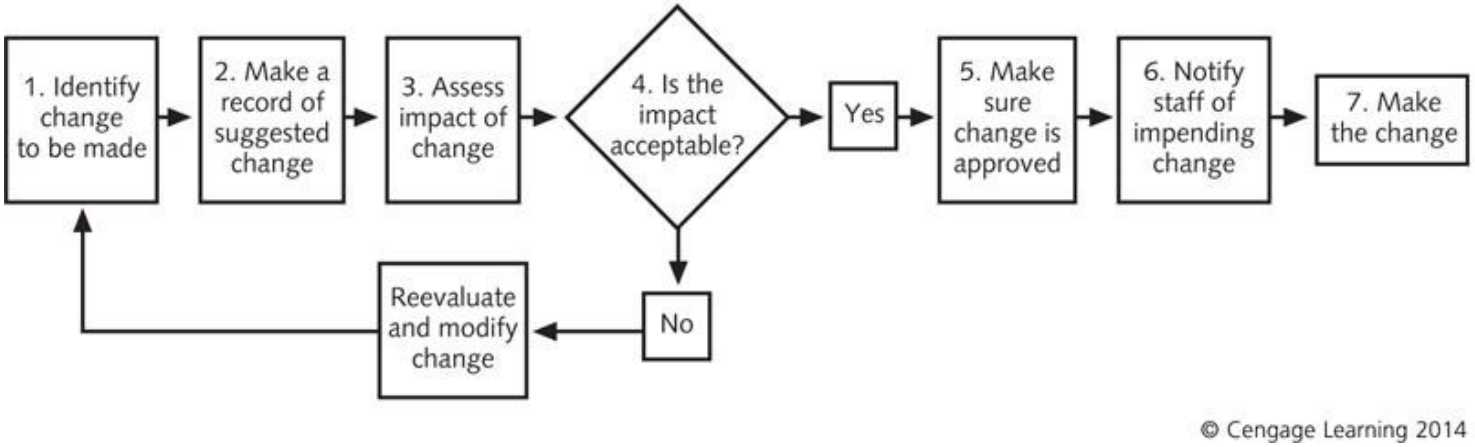

Figure 14-4 Significant changes should be evaluated and communicated systematically

Strengthening Analysis: Security Auditing

- Security auditing
  - Process of testing effectiveness of a network defense system
- Tiger teams
  - Groups assembled to actively test a network
  - Members have expertise in security
  - Commonly used in the past
- You need to put together data from several sources
  - Consolidate the data in a central database
  - Most IDPSs have a feature for transferring data

© Cengage Learning 2014

Operational Auditing, Part 1

- Operational audit
  - IT staff examines system logs
  - Determine whether they are auditing the right information
- Operational audit should look for the following
  - Accounts that have weak passwords or no passwords
  - Accounts assigned to employees who have left the company or user group
  - New accounts that need to be checked against a list of authorized users

© Cengage Learning 2014

Operational Auditing, Part 2

- Financial institutions have regular security audits
  - Because of government regulations
- Social engineering
  - Attempts to trick employees into giving out passwords or other information
- Tinkerbell program
  - Network connections are scanned
  - Generates alerts when suspicious connection attempts are made

© Cengage Learning 2014

Independent Auditing

- Independent audit
  - An outside firm inspects a company's audit logs to ensure that the organization is collecting the information it needs
- Outside firm attempts to detect any flaws or vulnerabilities in your system
- Auditor should sign a nondisclosure agreement (NDA)
  - In which they promise not to release information to anyone outside the audit firm

© Cengage Learning 2014

Strengthening Detection: Managing an IDPS

- As your network grows, amount of traffic grows too
- You might need to modify your IDPS rule base and amount of space available to IDPS

© Cengage Learning 2014

Maintaining Your Current System, Part 1

- Backups
  - Back up your firewall and IDPS in case of disaster
  - Help you restore the system
  - Other devices to backup
    - Routers
    - Bastion hosts
    - Servers
    - Special-purpose devices
  - Can use automated backup software
    - Especially for a large-scale network

© Cengage Learning 2014

Maintaining Your Current System, Part 2

- Managing accounts
  - Task often neglected
  - Involves
    - Adding new accounts
    - Recovering old ones
    - Changing passwords
  - Make sure accounts are reviewed every few months
- Managing IDPS rules
  - Eliminate unnecessary rules
    - Improves IDPS performance
  - Keep IDPS audit logs in a secure location

© Cengage Learning 2014

Maintaining Your Current System, Part 3

- User management
  - Security user-awareness program consists of training procedures that ensure employees, contractors, and business partners understand security policy
    - Teaches employees how to use the system more securely
  - Raise employee awareness
    - Give lectures
    - Show how easy is to crack a password
    - Prepare booklets for employees to read and sign

© Cengage Learning 2014

Changing or Adding Software, Part 1

- Once or twice a year, IDPS software vendors usually release updated software
- Get details on what sort of upgrade path is needed
- Ask whether the new version requires
  - Working with new data formats
  - Installing new supporting software

© Cengage Learning 2014

Changing or Adding Hardware, Part 2

- Can be expensive
  - Cost is usually outweighed by the cost of security incidents
- Consider adding consoles
  - Reduces the target-to-console ratio
    - Number of target computers on your network managed by a single command console
- Reevaluate the placement of sensors

© Cengage Learning 2014

Strengthening Defense: Improving Defense in Depth

- Defense in Depth (DiD)
  - Calls for security through a variety of defense techniques that work together to block attacks
- DiD calls for maintenance of the following areas
  - Availability
  - Integrity
  - Authentication
  - Confidentiality
  - Nonrepudiation

© Cengage Learning 2014

Active Defense in Depth, Part 1

- **Active defense-in-depth**: strong implementation of the DiD concept
  - Security personnel expect attacks will occur
  - Try to anticipate to attacks
- Calls for multiple levels of protection
- Requires respondents to think creatively and counter all possible threats
- Security personnel should be trained
  - To keep up with attacks and countermeasures

© Cengage Learning 2014

Active Defense in Depth, Part 2

- Steps for creating a training cycle
  - Training
  - Perimeter defense
  - Intrusion detection
  - Intrusion response
  - New security approaches

© Cengage Learning 2014

Adding Security Layers

- Protect a single network by protecting all interconnecting networks
- Goal is to establish trust
- Layers
  - Firewall and intrusion detection
  - Encryption and authentication
  - Virus protection
  - Access control
  - Information integrity through SSL and IPsec
  - Auditing

© Cengage Learning 2014

Strengthening Performance: Keeping Pace with Network Needs

- IDPS performance
  - Ability to capture packets and process them according to the rule base
- Factors that affect performance
  - Memory
  - Bandwidth
  - Storage

© Cengage Learning 2014

Managing Memory

- IDPS performance depends largely on the number of signatures it has to review
- IDPS needs to maintain connection state in memory
- Memory also stores
  - Information in cache
  - Databases containing IDPS configuration settings
- IDPS should have more than the minimum amount of RAM to maintain state information

© Cengage Learning 2014

Managing Bandwidth

- Devices need to process data as fast as it moves through the network
- IDPS should be able to handle 50% of bandwidth
  - Without losing the capacity to detect problems
- Intrusion detection begins to break down:
  - When bandwidth use exceeds 80% of network capacity
- If performance lags:
  - Upgrade immediately to a faster computer or network card

© Cengage Learning 2014

Managing Storage

- Some intrusions take place over long periods
  - Require storage of large amount of historical data
- Clear out storage media when it is full and when the information on it is no longer needed
  - Shred documents and files completely
    - Simply deleting or erasing files does not completely remove all information from the disk
- Degaussing
  - Magnetically erasing an electronic device

© Cengage Learning 2014

Staying Informed About Security Trends

- To stay current with latest trends in network security:
  - Maintain a list of industry contacts
  - Visit security-related Web sites
  - Chat with other professionals in the field
  - Participate in mailing lists and newsgroups
  - Subscribe to trade publications
  - Take certification tests

© Cengage Learning 2014

Web Sites

- Recommended Web sites
  - Center for Internet Security (*www.cisecurity.org*)
  - SANS Institute (*www.sans.org*)
  - CERT Coordination Center (*www.cert.org*)
  - https://www.cisa.gov/uscert/

© Cengage Learning 2014

Mailing Lists and Newsgroups

- Provide more current information about security issues and vulnerabilities
- Recommended mailing lists can vary based on preference.

© Cengage Learning 2014

Certifications

- Management should understand that certifications benefit the organization
- Recommended certifications
  - Based on the need
  - Normally security essentials can be found with many vendors

© Cengage Learning 2014

Summary, Part 1

- Security event management
  - Accumulating data from wide range of security devices
- Changes should be done in a systematic way
- Security auditing tests the effectiveness of network defenses
- Keep an IDPS running smoothly
  - Make backups
  - Manage user accounts
  - Reduce number of rules
  - Add hardware and software as needed

© Cengage Learning 2014

Summary, Part 2

- Defense in Depth
  - Improve overall network security
  - Anticipate and thwart attack attempts
- Keep pace with your network's needs
  - Memory
  - Bandwidth
  - Storage
- Delete files completely by "shredding" them electronically
- Stay current with latest security breaches and viruses

© Cengage Learning 2014